MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 072 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

ANNOTATED YEAR · RISK ASSESSMENT

3.11.1 Asks How Often You Assess Risk. Most Shops Never Said

NIST 800-171 control 3.11.1 is worth 3 SPRS points, and its first objective is a schedule. One risk assessment, followed month by month.

BY **MAXINE** READING TIME · 5 MIN NIST-800-171 · RISK-ASSESSMENT · SPRS · CMMC-LEVEL-2

The risk assessment requirement in NIST SP 800-171 is worth 3 points in the DoD Assessment Methodology, and the first thing an assessor checks is not the quality of the analysis. It is whether the program ever said how often it would do one. Objective 3.11.1[a] asks whether the frequency of risk assessment is defined. Objective 3.11.1[b] asks whether risk was assessed at that frequency. A shop that ran a careful assessment once, years ago, and never wrote down when the next one was due fails both objectives with the document in its hand.

The requirement is easier to see across a calendar than in the abstract, so follow one assessment through one year at a hypothetical thirty-person machine shop with a CUI enclave.

January, when the frequency gets written down

Nothing in 3.11.1 names an interval. The requirement says "periodically," and the objective leaves the period to the organization. NIST's own guide on the subject, SP 800-30 Rev. 1, explains why: risk assessments "are not simply one-time activities," and their frequency should be "commensurate with the expressly defined purpose and scope of the assessments" (Sec. 2.2).

So the shop's first act is a sentence in its risk assessment policy, not an analysis. It picks a standing interval it will actually keep. Then it does the part most programs skip and names the events that force an update between intervals. SP 800-30 lists this among the key activities of maintaining an assessment: identify "the circumstances under which the risk assessment needs to be updated" (Sec. 3.4). A new contract that brings new CUI, a new cloud service in the boundary and a reported incident are the obvious candidates. Writing them down in January is what lets the June update count as evidence rather than improvisation.

March, the assessment itself

The analysis is where programs spend their effort, and it is the part 3.11.1 grades least directly. SP 800-30 defines risk as "a function of the likelihood of a threat event's occurrence and potential adverse impact should the event occur" (Sec. 2.3). The requirement tells the shop what to measure the impact against: organizational operations, "including mission, functions, image, or reputation," organizational assets, and individuals, arising from systems that process, store or transmit CUI.

For a thirty-person shop that can be a plain table: each system in the enclave, the threat events that matter to it, a likelihood, an impact and a resulting rating, with an owner and a date on every row. The assessor's examine list for 3.11.1 names risk assessment results, reviews and updates alongside the policy and the security plan. A table with dates on it is all three.

The first objective is not about risk at all. It is about the calendar.

FIELD COPY
ISSUE Nº 072
NIST 800 171

3

SPRS POINTS ON 3.11.1, PERIODICALLY ASSESS THE RISK TO ORGANIZATIONAL OPERATIONS, ASSETS, AND INDIVIDUALS

2

ASSESSMENT OBJECTIVES ON 3.11.1, AND THE FIRST ASKS ONLY WHETHER THE FREQUENCY IS DEFINED

2012

YEAR NIST PUBLISHED SP 800-30 REV. 1, ITS GUIDE FOR CONDUCTING RISK ASSESSMENTS

◆ NOT THE SAME QUESTION AS 3.12.1

3.12.1, worth 5 points, asks a program to periodically assess its security controls to determine whether they are effective. 3.11.1 asks what could go wrong and how badly. A single document can answer both, but only if it answers each one on purpose.

June, a new contract changes the answer

Midyear, the shop wins a subcontract that sends a new category of drawings into the enclave, and it moves file exchange with that prime to a cloud service it had not used before. Both events are on the January list, so the program reopens the assessment, adds the new data flow and the new service, and rerates the rows they touch.

This is the step SP 800-30 calls maintaining the assessment: keeping it current "to incorporate any changes detected through risk monitoring," including "risk-impacting changes to organizational information systems and the environments in which those systems operate" (Sec. 3.4). It is also the step that ties the risk assessment to the rest of the paperwork. The same change belongs in the system security plan an assessor actually reads, and an assessor who sees the boundary grow in one document and not the other has found a finding either way.

October, the scans come back and need an order

The shop's vulnerability scans under 3.11.2 produce what scans always produce: a long list with vendor severity ratings. The scanning cadence piece covered how often those scans must run. What it left to this requirement is the question of what to fix first.

3.11.3 answers in one line: "Remediate vulnerabilities in accordance with risk assessments." Its second objective, 3.11.3[b], asks whether that happened, and the risk assessment is on its examine list. A severity score describes a flaw in general. The shop's own risk table describes what that flaw would cost this enclave, which is the ranking 3.11.3 asks the program to follow. An assessor reading the remediation record will reasonably ask which assessment it followed, and a program without a current one has no answer to give.

The next January, which is what the assessor reads

A year on, the shop repeats the full assessment on the date its policy named. That second dated document, with the June update between the two, is the evidence for 3.11.1[b]. One assessment shows a program can do the analysis. Two, at the interval it promised, show it does.

The cost of getting this wrong is specific. 3.11.1 carries 3 points, and a single unmet objective costs all of them. Under 32 CFR 170.21(a)(2), no requirement worth more than 1 point may sit on a Level 2 POA&M, as the POA&M eligibility piece laid out, so a missing frequency is a gap to close before the assessment, not one to carry past it. The 1 point on 3.11.3 leans on the same document. The analysis is real work, but the objective that fails first is a sentence in a policy and a date the program keeps.

If you want a second reader on whether your interval and your dates would hold up in front of an assessor, a readiness check is where to start. ◆